

FICHE DE RÉVISION - SÉCURITÉ DES APPLICATIONS MOBILES

ANDROID vs iOS - ARCHITECTURES

Distribution & Sandboxing

Android : Open source, stores alternatifs, sideloading APK possible (risque élevé). SELinux + App Sandbox (UID unique par app). Runtime permissions (Android 6.0+).

iOS : App Store exclusif (revue stricte). App Sandbox isolé + Code Signing obligatoire. Privacy prompts contextuels (iOS 14+).

Fragmentation & Mises à jour

Android : 1000+ versions actives, MAJ lentes (fabricant/opérateur).

iOS : >80% sur iOS 16+ en 6 mois, MAJ OTA rapides Apple direct.

Sécurité Kernel

Android : Linux Kernel, SELinux enforcing, Verified Boot.

iOS : XNU (Mach+BSD), Mandatory Code Signing, KASLR, Pointer Authentication.

Environnement Sécurisé

Android : TEE (ARM TrustZone), Android Keystore, StrongBox (Android 9+).

iOS : Secure Enclave (coprocesseur dédié), mémoire isolée, clés crypto.

SÉCURITÉ OFFENSIVE

Android - Surface Large

Sideloading APK, multiplicité OEM, fragmentation patches, root accessible.

Attaques : Malware trojanisé, Banking trojans, Overlay attacks.

Coût : Exploitation moins coûteuse, attaques de masse.

iOS - Surface Restreinte

Écosystème fermé, signature obligatoire, jailbreak complexe.

Attaques : Exploits kernel zero-day, chaînes Pegasus-like, WebKit.

Coût : Exploits rares, chers, sophistiqués, attaques ciblées.

MENACES MOBILES

15% apps infectées | **30%** apps vulnérables réseau | **+50%** phishing/an | **43%** vol données

Types de Menaces

Malware : Trojans, Spyware, Ransomware, Banking Trojans.

Réseau : MitM, SSL Stripping, Evil Twin, DNS Spoofing.

Phishing : Smishing (SMS), Fake Apps, Quishing (QR), Vishing.

Vol données : SQLite non chiffré, logs exposés, clipboard, SD card.

Vecteurs d'Attaque

Apps tierces (>90% infections), Permissions excessives (90%+), WiFi publics, Bluetooth/NFC (BlueBorne), Composants exportés.

ARCHITECTURE ANDROID

5 Couches

1. Applications (Gmail, Chrome, apps tierces)
2. Application Framework (Activity/Package Manager, APIs)
3. ART + Native Libraries (OpenSSL, SQLite, WebKit)
4. HAL (Hardware Abstraction Layer)
5. Linux Kernel (drivers, SELinux, namespaces)

Sandbox Android

UID unique : Range 10000-19999, isolation processus/fichiers.

Répertoire privé : /data/data/ permission 700.

IPC sécurisé : Binder, Intent avec permissions, ContentProvider.

SELinux : MAC enforcing, politiques strictes par domaine.

4 Types de Permissions

Normal : Auto sans confirmation (INTERNET, BLUETOOTH).

Dangerous : Consentement requis (CAMERA, LOCATION, SMS).

Signature : Même certificat système (INSTALL_PACKAGES).

Special : Action utilisateur (SYSTEM_ALERT_WINDOW).

9 Groupes Permissions Dangereuses

CALENDAR, CAMERA, CONTACTS, LOCATION, MICROPHONE, PHONE, SENSORS, SMS, STORAGE

Runtime Permissions (Android 6.0+)

1. checkSelfPermission() - vérifier
2. shouldShowRequestPermissionRationale() - expliquer
3. requestPermissions() - demander
4. onRequestPermissionsResult() - gérer

Bonnes pratiques : Demander au moment de l'utilisation, expliquer l'utilité, gérer le refus gracieusement.

Pièges : Tout demander au lancement, ne pas vérifier (révocable), crasher si refusé.

4 Composants Android

Activity : Interface utilisateur (exported=false par défaut).

Service : Traitement arrière-plan.

BroadcastReceiver : Écoute événements (BOOT, SMS).

ContentProvider : Partage données inter-apps.

Risque exported=true : Activity lancée par tous, Service exécution arbitraire, ContentProvider accès données, BroadcastReceiver injection intents.

Protection : android:exported="false", android:permission, validation intents, signature-level.

Android KeyStore

Clés non extractibles, protection TEE/StrongBox.

Opérations : AES-GCM, RSA-OAEP, ECDSA, RSA.

Architecture : App - KeyStore API - daemon - TEE/StrongBox.

TEE & StrongBox

ARM TrustZone : Normal World vs Secure World, isolation hardware, SMC.

StrongBox (9+) : HSM séparé, CPU/mémoire/stockage isolés, résistance side-channel.

Usages : KeyStore, biométrie, WideVine DRM, Trusted UI.

Stockage Sécurisé

EncryptedSharedPreferences : AES-256-GCM valeurs, AES-256-SIV clés.

EncryptedFile : AES-256-GCM fichiers.

SQLCipher : AES-256 base SQLite (10% perf).

ARCHITECTURE iOS

Stack iOS (bas vers haut)

1. Core OS : Kernel XNU (Mach+BSD)
2. Core Services : Foundation, Core Data, CloudKit
3. Media Layer : AVFoundation, Core Graphics, Metal
4. Cocoa Touch : UIKit, SwiftUI, ARKit

Secure Boot Chain

1. Boot ROM (iBoot) - code immuable, racine confiance
2. LLB (Low-Level Bootloader) - vérifié signature Apple
3. iBoot (2nd stage) - vérifié par LLB
4. iOS Kernel (XNU) - vérifié par iBoot
5. Kernel Extensions - vérifiées par kernel

Échec vérification = arrêt immédiat (recovery/DFU)

Protection rollback via nonces SHSH.

Secure Enclave

Coprocesseur ARM dédié, sepOS (microkernel Mach), mémoire chiffrée isolée.

Fonctions : Clés crypto non exportables, Touch ID/Face ID, Apple Pay, TRNG, AES-256.

Code Signing

Certificats : Development (<100 devices), Ad Hoc (100 max), App Store, Enterprise.

Provisioning : embedded.mobileprovision (cert + App ID + devices + entitlements).

Expiration : 7 jours (gratuit), 1 an (payant).

Vérification : Signature à chaque lancement, intégrité binaire, entitlements.

App Store Review

1. Analyse auto : malware scan, API privées
2. Review manuelle : guidelines, contenu
3. Tests fonctionnels : crash, comportement
4. Vérification métadonnées

Rejets : API privées, collecte sans consentement, bugs critiques, spam.

Limites : Non infallible, 24-48h délai, bypass JS hot-patching.

iOS Sandbox & Permissions

Container : Bundle/ (lecture seule, signé), Documents/ (iCloud), Library/ (caches), tmp/.

Permissions Info.plist : NSCameraUsageDescription (iOS 10+), NSLocationWhenInUseUsageDescription, NSMicrophoneUsageDescription, NSContactsUsageDescription, NSFaceIDUsageDescription.

Keychain & Data Protection

Keychain : AES-256, géré securityd, clés Secure Enclave. Types : GenericPassword, InternetPassword, Certificate, Key, Identity. Accessibilité : kSecAttrAccessibleWhenUnlocked (recommandé).

Data Protection - 4 classes :

Complete : Inaccessible verrouillé (max sécurité).

CompleteUnlessOpen : Ouvert avant verrouillage.

CompleteUntilFirstUserAuthentication : Après 1er unlock (défaut).

None : Toujours accessible (éviter données sensibles).

POINTS CLÉS

Android

Sandbox UID + SELinux | 4 types permissions | Runtime 6.0+ | 9 groupes dangerous | 4 composants | KeyStore TEE/StrongBox | EncryptedSharedPreferences

iOS

Secure Boot Chain | Code Signing obligatoire | Secure Enclave | App Store Review | Keychain | 4 classes Data Protection | Sandbox container isolé

Comparaison

Android : Plus ouvert, surface large, attaques masse.

iOS : Plus fermé, surface restreinte, attaques ciblées sophistiquées.